Natalyx MVP Fixes

Work Package 03: Authentication, invitations, and resume

L. Rhodes (plan owner) - A. Zhao (technical review requested)

2026-07-10

Contents

1 Work Package 03: Authentication, invitations, and resume **2**

1.1 Purpose and outcome 2
1.2 Verified current-state evidence 3
1.3 Architecture and contracts 3
1.4 Explicit PR sequence 9
1.5 Cross-repository coordination 18
1.6 Test and acceptance matrix 19
1.7 Risks and decisions 19
1.8 Existing-work salvage 20
1.9 Ownership recommendation 21
1.10 Definition of done 22

1 Work Package 03: Authentication, invitations, and resume

> Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP03
Plan file	`WP03 - Authentication, invitations, and resume.md`
Proposed PRs	P03-01, P03-02, P03-03, P03-04
Inspection snapshot	2026-07-10 20:12 America/New_York

1.1 Purpose and outcome

Problem. Current invitation code mixes low-risk onboarding links with case membership, and existing flows need explicit recipient binding, return-to safety, consent, expiry, revocation, duplicate-claim, and mismatch semantics.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. Separate workspace-claim and paid-case invitation lifecycles with safe authentication/resume behavior and no link-possession path to sensitive case access.

Explicit non-goals.

- No automatic paid-case membership

- No email deliverability product
- No commercial promotion
- No PHI enablement

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-006	verified	app / PR #122@e853821	PR comment Review round 2 addressed and changed workflow/tests	Updated PR #122 reports 499 tests plus return_to, TTL, CAS, self-invite, lens and Learn fail-closed fixes; green checks were observed. These are salvage candidates, not blanket merge approval.
E-011	verified	app / PR #124@84a5a84	app/storage/node0.py:400-462; app/routes/node0.py:605-652	Node 0 can issue an unaddressed GC invitation and redemption ultimately creates case membership, violating low-risk onboarding possession with case access.
E-012	verified	app / PR #122@e853821	app/storage/invitations.py and PR review-round comment	The updated case invitation work adds 14-day ceiling, CAS transitions, mismatch confirmation, self-invite refusal, return_to preservation and paired lens tests; it has no Node 0 workspace target.

1.3 Architecture and contracts

- An email-less link may create a pending low-risk workspace claim only.
- Paid-case membership requires authenticated identity binding, recipient or issuer confirmation as appropriate, explicit consent, and auditable redemption.
- Return targets are internal allowlisted paths and survive login/signup/confirmation without becoming redirect authority.

Contract area	Package rule
Ownership boundary	`app`, `infra`; repository-specific PRs remain separate.
Entities/state	`case_invitation`, `entry_session`, `workspace_claim`
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.

Contract area	Package rule
API/service	Auth routes accept only allowlisted relative return targets. Issue, inspect, bind, consent, claim, revoke endpoints. Separate paid-case redeem/confirm flow. Client metadata carries opaque admission proof only.
Storage	Workspace claims and audit/idempotency fields. Case-invitation identity, consent, expiry, revocation, idempotency fields.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.3.1 Applicable state machines

1.3.2 Participant entry and routing (`entry_session`)

Owner: **natalyx-app**. States: `unstarted`, `education`, `identity_required`, `authenticated`, `routed`, `handed_off`, `expired`.

Transition: `unstarted` -> `education`

- **Actor:** visitor
- **Evidence:** GET/explicit entry choice
- **Idempotency key:** `entry:{session}:start`
- **Invalid transitions:** No participant/case write
- **Audit event:** `entry_started`
- **Retry:** Return current session
- **Recovery:** Create fresh anonymous session

Transition: `education` -> `identity_required`

- **Actor:** visitor/policy
- **Evidence:** route requires saved workspace
- **Idempotency key:** `entry:{session}:identity`
- **Invalid transitions:** Cannot grant workspace/case
- **Audit event:** `identity_required`
- **Retry:** Preserve safe return intent

- **Recovery:** Restart at public choice

Transition: `identity_required -> authenticated`

- **Actor:** Cognito/auth provider
- **Evidence:** verified subject/session
- **Idempotency key:** `auth:{subject}:{nonce}`
- **Invalid transitions:** Invalid/expired token
- **Audit event:** `identity_bound`
- **Retry:** Replay returns authenticated session
- **Recovery:** Rechallenge; no partial membership

Transition: `education|authenticated -> routed`

- **Actor:** participant + deterministic policy
- **Evidence:** validated route answers + policy version
- **Idempotency key:** `route:{session}:{answer_hash}`
- **Invalid transitions:** Unknown/unsafe route goes review/education
- **Audit event:** `entry_routed`
- **Retry:** Same input returns same decision
- **Recovery:** Allow corrected answers/new decision revision

Transition: `routed -> handed_off`

- **Actor:** participant
- **Evidence:** accepted destination and authorized target
- **Idempotency key:** `handoff:{session}:{route_version}`
- **Invalid transitions:** Target not authorized/available
- **Audit event:** `entry_handed_off`
- **Retry:** Resume same safe destination
- **Recovery:** Return to route result with explanation

Transition: `any nonterminal -> expired`

- **Actor:** system
- **Evidence:** TTL elapsed/revoked session
- **Idempotency key:** `entry:{session}:expire`
- **Invalid transitions:** No transition from handed_off needed
- **Audit event:** `entry_expired`
- **Retry:** Idempotent
- **Recovery:** New session; no case/access change

1.3.3 Low-risk workspace identity claim (`workspace_claim`)

Owner: **natalyx-app**. States: `issued`, `pending_identity`, `identity_bound`, `consented`, `claimed`, `mismatch_pending`, `revoked`, `expired`.

Transition: `none -> issued`

- **Actor:** workspace IP
- **Evidence:** selected candidate + allowed claim scope
- **Idempotency key:** `claim:{workspace}:{candidate}:{generation}`
- **Invalid transitions:** Existing live claim superseded
- **Audit event:** `workspace_claim_issued`
- **Retry:** Return current token only at issuance
- **Recovery:** Issue new generation; old revoked

Transition: `issued -> pending_identity`

- **Actor:** link holder
- **Evidence:** valid token landing
- **Idempotency key:** `claim:{id}:land`
- **Invalid transitions:** Expired/revoked token
- **Audit event:** `claim_opened`
- **Retry:** Safe repeat
- **Recovery:** Authenticate or exit; no data grant

Transition: `pending_identity -> identity_bound|mismatch_pending`

- **Actor:** auth provider
- **Evidence:** verified subject/email and binding policy
- **Idempotency key:** `claim:{id}:bind:{subject}`
- **Invalid transitions:** Already claimed/different subject
- **Audit event:** `claim_identity_bound|claim_mismatch`
- **Retry:** CAS no-op or mismatch state
- **Recovery:** Issuer review/new claim

Transition: `identity_bound -> consented`

- **Actor:** GC claimant
- **Evidence:** workspace consent version
- **Idempotency key:** `claim:{id}:consent:{version}`
- **Invalid transitions:** Stale/missing consent
- **Audit event:** `claim_consented`
- **Retry:** Idempotent
- **Recovery:** Display current consent

Transition: `consented -> claimed`

- **Actor:** claim service
- **Evidence:** authorized low-risk workspace membership transaction
- **Idempotency key:** `claim:{id}:complete`
- **Invalid transitions:** Case membership requested or conflicting claimant
- **Audit event:** `workspace_claimed`
- **Retry:** Return same membership
- **Recovery:** Transaction rollback/forward repair

Transition: `issued|pending_identity|identity_bound|consented|mismatch_pending -> revoked|expired`

- **Actor:** issuer/system
- **Evidence:** revocation or TTL
- **Idempotency key:** `claim:{id}:terminal:{event}`
- **Invalid transitions:** No terminal overwrite
- **Audit event:** `claim_revoked|claim_expired`
- **Retry:** Idempotent
- **Recovery:** Fresh claim only

1.3.4 Paid-case membership invitation (`case_invitation`)

Owner: **natalyx-app**. States: `issued`, `pending_identity`, `identity_bound`, `mismatch_pending`, `issuer_confirmed`, `consented`, `redeemed`, `declined`, `revoked`, `expired`, `superseded`.

Transition: `none -> issued`

- **Actor:** authorized IP case member
- **Evidence:** enrollment_pending/active case + recipient binding
- **Idempotency key:** `case-invite:{case}:{role}:{generation}`
- **Invalid transitions:** Self/member/active-GC/unauthorized
- **Audit event:** `case_invite_issued`
- **Retry:** Return current; supersede prior live GC invite
- **Recovery:** Issue corrected invite

Transition: `issued -> pending_identity`

- **Actor:** recipient
- **Evidence:** valid addressed token landing
- **Idempotency key:** `case-invite:{id}:land`
- **Invalid transitions:** Expired/revoked
- **Audit event:** `case_invite_opened`
- **Retry:** Safe repeat
- **Recovery:** Authenticate with return_to

Transition: `pending_identity -> identity_bound|mismatch_pending`

- **Actor:** auth provider
- **Evidence:** verified subject/email
- **Idempotency key:** `case-invite:{id}:bind:{subject}`
- **Invalid transitions:** Terminal/duplicate/different subject
- **Audit event:** `case_invite_bound|mismatch`
- **Retry:** CAS protects terminal
- **Recovery:** Issuer confirmation or corrected invite

Transition: `mismatch_pending -> issuer_confirmed`

- **Actor:** authorized issuer
- **Evidence:** explicit reviewed mismatch confirmation
- **Idempotency key:** `case-invite:{id}:confirm:{issuer}`
- **Invalid transitions:** Issuer unauthorized/recipient changed
- **Audit event:** `case_invite_mismatch_confirmed`
- **Retry:** CAS no-op
- **Recovery:** Revoke and reissue

Transition: `identity_bound|issuer_confirmed -> consented`

- **Actor:** invitee
- **Evidence:** paid-case role/privacy consent version
- **Idempotency key:** `case-invite:{id}:consent:{version}`
- **Invalid transitions:** Stale/missing consent
- **Audit event:** `case_invite_consented`
- **Retry:** Idempotent
- **Recovery:** Present current consent

Transition: `consented -> redeemed`

- **Actor:** invitation service
- **Evidence:** single transaction creates person/party/membership
- **Idempotency key:** `case-invite:{id}:redeem`
- **Invalid transitions:** Existing member/active GC/expired/revoked
- **Audit event:** `case_invite_redeemed`
- **Retry:** Return same membership
- **Recovery:** Rollback entire transaction; forward repair from invite

Transition: `issued|pending_identity|identity_bound|mismatch_pending|issuer_confirmed|consented -> declined|revoked|expired|superseded`

- **Actor:** invitee/issuer/system
- **Evidence:** explicit decline/revoke/TTL/new generation
- **Idempotency key:** `case-invite:{id}:terminal:{event}`
- **Invalid transitions:** No terminal overwrite
- **Audit event:** `case_invite_terminal`
- **Retry:** Idempotent CAS
- **Recovery:** Fresh invitation only

1.3.5 Invitation and identity safety

Retain from updated PR #122:

- hashed tokens
- purpose-specific TTL with a 14-day ceiling
- CAS terminal transitions

- atomic membership creation
- one-live-GC constraint
- self/existing-member refusal
- safe return_to
- portable integrity/concurrency tests

Required replacement contract:

- Exactly one target: workspace_id or case_id; include purpose, role, access_class, recipient_binding_mode and policy version.
- Email-less possession may only open pending low-risk workspace claim; it cannot reveal sensitive data or grant paid-case membership.
- Paid-case invitation is addressed, authenticated, consented and atomically redeemed; mismatch requires explicit policy/issuer handling and preferably fresh bound token.
- Cognito admission and app membership are separate decisions; account creation never equals workspace/case access.
- Verified identity comes from auth claims, not form-entered email; duplicate claims return the original result.
- Never put raw token/email/PHI in general participant timeline payloads; revoke/expire/supersede fail closed.
- Remove generic unconditional status mutation; expose authorized transition commands only.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Size	Readiness
1	P03-01	Harden auth return-to and participant resume	app	P01-01	A1	Medium	Dependencies unmet
2	P03-02	Add low-risk workspace claim lifecycle	app	P03-01, P04-01	A1	Large	Dependencies unmet
3	P03-03	Bind paid-case invitations to identity and consent	app	P03-01, P04-01	A2	Large	Dependencies unmet
4	P03-04	Replace shared signup admission with claim-aware Cognito admission	infra	P03-02, P03-03	A1	Large	Blocked by decision

1.4.1 P03-01 - Harden auth return-to and participant resume

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A1 / Medium / Dependencies unmet

Field	Plan
Dependencies	P01-01
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	PR #122 return_to fixes

1.4.1.1 Objective Make signup/login/confirmation/logout preserve a validated internal destination and restore the correct role-scoped workspace without query parameters becoming authority.

1.4.1.2 Scope

- Central safe_return_to parser
- Resume intent across login/signup/confirm/resend
- Session/cookie security and error states

1.4.1.3 Explicit non-goals

- No invitation issuance
- No case access grant

1.4.1.4 Expected files or modules

- `app/auth/routes.py`
- `app/auth/cloud.py`
- `app/auth/cognito.py`
- `tests/python/test_auth_routes.py`
- `tests/python/test_auth_cloud_integration.py`

1.4.1.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	Auth routes accept only allowlisted relative return targets.
UI/product surface	Clear expired/failed session recovery.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.1.6 Tests and validation Objective tests:

- Open redirect corpus

- logged-out deep link
- signup confirmation
- logout/login resume
- secure/samesite cookie matrix

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.1.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.1.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.1.10 Dependencies and parallel work Hard dependencies: P01-01. Parallel opportunities: P03-04

1.4.1.11 Objective acceptance criteria

- ☐ Make signup/login/confirmation/logout preserve a validated internal destination and restore the correct role-scoped workspace without query parameters becoming authority.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke

Role	Recommendation
Required expertise	Cognito, web session security, FastAPI
Higher-capability review	Risk-proportionate; not mandatory by programme default

1.4.2 P03-02 - Add low-risk workspace claim lifecycle

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A1 / Large / Dependencies unmet
Dependencies	P03-01, P04-01
Blocking decisions/checkpoints	D-AUTH-01, CHECK-ALAN-122-124
Source / salvage	PRs #123/#124, dirty onboarding-link worktree

1.4.2.1 Objective Create a pending Node 0 workspace claim that can start from an unaddressed link but requires identity binding, consent, expiry, revocation, and audit before low-risk access.

1.4.2.2 Scope

- Hashed one-time token and claim state machine
- Identity bind/consent/revoke/duplicate/mismatch behavior
- No sensitive case scope

1.4.2.3 Explicit non-goals

- No paid-case membership
- No possession-only private access

1.4.2.4 Expected files or modules

- `app/storage/workspace_claims.py`
- `app/routes/node0_claims.py`
- `app/templates/node0/claim*.html`
- `tests/python/test_workspace_claims.py`

1.4.2.5 Change map

Area	Planned change
Schema/model	Workspace claims and audit/idempotency fields.
API/routes	Issue, inspect, bind, consent, claim, revoke endpoints.
UI/product surface	Low-risk claim and mismatch screens.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.

Area	Planned change
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.2.6 Tests and validation Objective tests:

- Forwarded link
- duplicate/concurrent claim
- expiry/revocation
- identity mismatch
- issuer visibility

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.2.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.2.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.2.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.2.10 Dependencies and parallel work Hard dependencies: P03-01, P04-01. Parallel opportunities: P03-03

1.4.2.11 Objective acceptance criteria

- ☐ Create a pending Node 0 workspace claim that can start from an unaddressed link but requires identity binding, consent, expiry, revocation, and audit before low-risk access.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.2.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	Python/FastAPI, PostgreSQL, security-aware product engineering
Higher-capability review	Mandatory before merge

1.4.3 P03-03 - Bind paid-case invitations to identity and consent

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Large / Dependencies unmet
Dependencies	P03-01, P04-01
Blocking decisions/checkpoints	D-AUTH-01, CHECK-ALAN-122-124
Source / salvage	PR #122 CAS/TTL/self-invite fixes, current invitations.py

1.4.3.1 Objective Implement a separate recipient-bound paid-case invitation that grants membership only after authenticated binding, required confirmation, consent, and case/role checks.

1.4.3.2 Scope

- Case invite CAS transitions
- Recipient/issuer mismatch confirmation
- Consent-version capture and membership transaction

1.4.3.3 Explicit non-goals

- No workspace token reuse
- No automatic GC migration from soft onboarding

1.4.3.4 Expected files or modules

- `app/storage/case_invitations.py`
- `app/case_members.py`
- `app/routes/case.py`
- `tests/python/test_case_invitations.py`

1.4.3.5 Change map

Area	Planned change
Schema/model	Case-invitation identity, consent, expiry, revocation, idempotency fields.
API/routes	Separate paid-case redeem/confirm flow.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Membership grant is a single authorized transaction.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.3.6 Tests and validation Objective tests:

- Replay
- self-invite
- active-member duplicate
- mismatch
- expired/revoked
- concurrent redemption rollback

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.3.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.3.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.3.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.3.10 Dependencies and parallel work Hard dependencies: P03-01, P04-01. Parallel opportunities: P03-02

1.4.3.11 Objective acceptance criteria

- ☐ Implement a separate recipient-bound paid-case invitation that grants membership only after authenticated binding, required confirmation, consent, and case/role checks.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.3.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	Python/FastAPI, PostgreSQL, security-aware product engineering
Higher-capability review	Mandatory before merge

1.4.4 P03-04 - Replace shared signup admission with claim-aware Cognito admission

Field	Plan
Repository / base	`infra` (`main`)
Gate / size / readiness	A1 / Large / Blocked by decision
Dependencies	P03-02, P03-03
Blocking decisions/checkpoints	D-AUTH-02
Source / salvage	infra platform-stack.ts current allowlist + shared invite code

1.4.4.1 Objective Keep internal/dev allowlisting but add a short-lived, recipient-bound admission proof for approved workspace/case claimants so a shared invite code is never the participant trust boundary.

1.4.4.2 Scope

- One-time signed or server-verified admission proof
- Email/purpose/claim/expiry binding
- Replay/revocation/audit
- No membership grant in Cognito

1.4.4.3 Explicit non-goals

- No open self-signup
- No Cognito group as case authority
- No shared user-entered master code

1.4.4.4 Expected files or modules

- `lib/stacks/platform-stack.ts`
- `lib/constructs/auth-admission.ts`
- `test/auth-admission.test.ts`
- `docs/agents/platform-stack.md`

1.4.4.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	Client metadata carries opaque admission proof only.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	Harden pre-signup Lambda and key/claim verification contract; keep missing config fail closed.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.4.6 Tests and validation Objective tests:

- Wrong email/purpose
- expired/replayed proof
- revoked claim
- internal allowlist path
- missing key/config
- membership still denied before app redemption

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **A1** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.4.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.4.8 Rollout Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

1.4.4.9 Rollback or forward repair Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

1.4.4.10 Dependencies and parallel work Hard dependencies: P03-02, P03-03. Parallel opportunities: P03-01

1.4.4.11 Objective acceptance criteria

- ☐ Keep internal/dev allowlisting but add a short-lived, recipient-bound admission proof for approved workspace/case claimants so a shared invite code is never the participant trust boundary.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.4.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	Cognito, AWS Lambda/KMS, identity security
Higher-capability review	Mandatory before merge

1.5 Cross-repository coordination

Repository	Authority after merge
`app`	routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain
`infra`	AWS resources, IAM/KMS/network/deployment/backup/audit contracts

Merge order inside this package: `P03-01` → `P03-02` → `P03-03` → `P03-04`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	Logged-out resume; Token replay/expiry/revocation; Duplicate and concurrent claims; Identity mismatch; Workspace-to-case access escalation	Expected state/event/UI and named evidence are produced once.
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Type	ID / risk	Owner	Affected PRs / latest point	Treatment
Blocking/product/compliance decision	D-AUTH-01 - Which low-risk fields may a link-only claimant see, when is recipient/issuer confirmation required, and what consent/version binds each access elevation?	Luke	P03-02, P03-03; Before P03-02	D-AUTH-01 - Link possession creates pending workspace claim only; paid-case access always requires authenticated binding and explicit consent.
Blocking/product/compliance decision	D-AUTH-02 - Choose a short-lived signed/server-verified participant admission proof and key/claim lifecycle while retaining a separate internal allowlist path.	Luke	P03-04; Before P03-04	D-AUTH-02 - Bind proof to email, purpose, claim ID and expiry; it admits account creation only and never grants workspace/case membership.
Implementation risk	Shared links forwarded	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Account mismatch	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Confused-deputy redirects	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Workspace data exposed during upgrade	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#122	e85382150853	Case projection/lens surfaces, safe return_to, invitation TTL/CAS/self-member/one-GC constraints, transactional membership, fail-closed Learn, SQL-limited timeline, responsive/a11y tests and Python CI workflow.	P03-01, P03-03	Retain pending Alan reconciliation; selective port or rebase only after architecture approval	Reinspected at latest head. It is exactly e853821 (no newer delta); retention strengthened, but final extraction waits for Alan checkpoint.
app#123	34078f810b63	GC onboarding form/copy, hosted auth return, invite handoff and role-specific surface work.	P03-01, P03-02	Selective UX/test port and rewrite	Unextracted; likely partially copied into #124 but not proven complete.
feature/node0-surrogate-onboarding-link	529d377	substantial uncommitted onboarding/invitation work	P03-02/P03-03/P06-02	Selective port from protected worktree	Preserve until file/test extraction is signed off.

Package source inventory:

- PR #122 return_to, CAS, TTL, self-invite and mismatch fixes
- PRs #123/#124 hosted GC onboarding UX
- Dirty onboarding-link worktree

1.9 Ownership recommendation

Alan proposes implementation and threat-model details; Luke approves role/privacy policy. Replacement work waits for the Alan PR-reconciliation checkpoint.

PR	DRI	Implementer	Reviewer	Final approver	External/high-capability review
P03-01	Alan	Alan (proposed)	Luke	Luke	As risk warrants
P03-02	Alan	Alan (proposed)	Luke	Luke	Mandatory
P03-03	Alan	Alan (proposed)	Luke	Luke	Mandatory
P03-04	Alan	Alan (proposed)	Luke	Luke	Mandatory

Luke decides product/lifecycle/commercial/privacy/PHI/provider policy and accepts gates. Alan proposes implementation design, decomposition, migrations, code, tests, rollout and repair. This is a recommendation pending Alan's review/sign-off, not a compulsory assignment.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.